Sprint 4 SonarQube Static Review - Seth Martin

Student: Seth Martin | **Project:** Rate My Fries (FRY) | **Submission:** Sprint 4.

Report date: November 3, 2026. Snapshot verified from live Jira/GitHub; times use America/Chicago. October 20 was CDT (UTC-05:00); November 3 is CST (UTC-06:00).

Tool and completed execution

Actual dashboard/API export from SonarQube 26.10.0.133078 Community Build, run locally on Docker Desktop with the official SonarScanner CLI image. The scanner completed successfully and its server processing task is SUCCESS. Scanner logs, task ID, image digests and raw JSON are included. The ephemeral scanner token was revoked after export.

Required metrics

Metric	Current tool value
Bugs	0
Vulnerabilities	1
Code smells	0
Security hotspots	0
Overall imported coverage	66.1%
Duplicated-line density	0.0%
Quality Gate status	OK

Gate limitation: the API returned OK with **0 evaluated conditions** for this new analysis project. This is not a clean-security result: one BLOCKER vulnerability remains open. No finding was suppressed, dismissed or marked safe. No source or deployed AWS changes were made for this reporting request.

Finding and manual assessment

Rule / tool severity	Location	Open finding
cloudformation:S6304 / BLOCKER	infra/private-ec2.template.json:230	Make sure granting access to all resources is safe here.

The affected IAM statement grants read/list EC2 and SSM metadata actions on Resource '*'. It does not grant arbitrary AWS administration or unrelated instance writes. Some list/describe actions require wildcard resource scope, but GetConnectionStatus supports instance-level resources and can be split into a statement scoped to the Fry instance. Review the remaining metadata access and document the unavoidable wildcard actions. Keep the issue open until that review/remediation and a rescan are complete.

Primary reference: AWS Systems Manager action/resource authorization. Source: pinned EC2 template. This is an assessment of the actual flagged statement, not a reclassification of Sonar's severity.

Exact scan scope

This is an **analysis-only composite**, not a merged branch or a claim that main contains pending changes. All 42 source files were exported from Git before scanning:

Source	Exact revision
Deployed runtime (pending #7/#9/#10 combination)	d094cd8e52b1dcf413ed1a36209a367abe525262
Catalogue importer/data/tests (#8)	bb9673abc28c0a0060d6292facdc77363a69145b
EC2 template/bootstrap/tools/tests (#11)	d7b7bf5ed9ffa6c6562f91223609e65a0635c1c9

Source-manifest SHA-256: `29b4cfd5a586b98a29a9bab4eb49e6a78b66ca749261122e091b82d64724abf4`. The manifest records the originating revision and SHA-256 for every source file. The snapshot includes Python, JavaScript, HTML/Jinja, CSS, shell, PowerShell, JSON/CloudFormation and the SQL schema. Analyzer support differs by language; including a file does not imply a dedicated analyzer for every format. Source scope expanded from 917 to 1910 Sonar non-comment lines.

Git history, databases, signing keys, Google/API configuration, virtual environments, prior reports, demos and IDE files were excluded. Tests are classified separately from production source. Coverage XML and a resolved Python dependency inventory were generated for the scan. No deployment image or running AWS account was scanned.

Trend and coverage

Metric	October 20 baseline	November 3 review
Bugs	0	0
Vulnerabilities	0	1
Code smells	0	0
Security hotspots	0	0
Overall coverage	82.2%	66.1%

The previous Sprint 3 baseline is the October 20 scan at b93baae14b9fefb54077c02bad7f740cb358902b. Its original report and raw exports remain preserved. The scanner project identifier retains its original Sprint3 label; this submission is Sprint 4. The new finding is in newly included infrastructure. Overall coverage has fallen across the expanded production-source scope, including operational scripts not exercised by the Python suite; this is not a like-for-like application-only coverage regression measurement. The earlier CSRF/form fixes remain part of the runtime.

Reflection and next steps

The application-focused baseline missed the newly added infrastructure risk surface. Review wildcard permissions before merging #11, preserve the useful per-instance write restrictions, and add coverage for operational paths where practical. Re-run SonarQube after any approved remediation. The analysis-only snapshot passed 72 Python tests and 12 JavaScript checks; runtime/permission acceptance is separate evidence and does not erase static findings.

This static analysis was generated using automated tools during this sprint.

Evidence: sonarqube-metrics.json, sonarqube-issues.json, sonarqube-hotspots.json, sonarqube-quality-gate.json, sonarqube-task.json, sonar-scanner.log, sonar-versions.json and scan-metadata.json in the accompanying raw evidence.